



GOVERNED INNOVATION SERIES

THE AI GOVERNANCE PLAYBOOK

A Practical Guide for Federal Agencies

Deploying Responsible AI Without Compromising Audit Readiness

January 2026

New South Technologies
info@newsouthtechnologies.com

01 | INTRODUCTION

Modernization Without Accountability Isn't Progress — It's Risk.

Artificial Intelligence offers unprecedented opportunities for federal agencies to improve service delivery, detect fraud, optimize resource allocation, and enhance decision-making. But AI also introduces unique risks: bias, opacity, data privacy violations, and mission-critical failures that can trigger OIG investigations.

This Playbook provides a practical framework for deploying AI systems that are not only effective but also compliant with NIST AI RMF, OMB M-26-04, FISMA, and FedRAMP requirements.

Who Should Use This Guide

- Agency CIOs & CISOs overseeing AI initiatives
- Program Managers implementing AI-driven solutions
- ISSOs & Security Teams validating AI controls
- Contractors building AI systems for federal clients
- Authorizing Officials evaluating AI authorization packages

By the end of this Playbook, you will have:

- A checklist for AI system assessment before deployment
- Templates for documenting model transparency and explainability
- Integration points for existing NIST RMF compliance workflows
- Strategies for continuous monitoring and risk management

02 | REGULATORY LANDSCAPE

What You Must Know

Three Major Mandates Drive Federal AI Governance

1

NIST AI Risk Management Framework (AI RMF)

Published January 2023 • Four Core Functions: Govern, Map, Measure, Manage • Key Document: NIST AI 100-1

Required for all AI systems handling federal data.

2

OMB Memorandum M-26-04 (Unbiased AI Principles)

Issued late 2025 • Requires empirical bias mitigation evidence before contract award • Mandates explainability for high-stakes decisions.

Applies to any system affecting civil rights, benefits, or eligibility.

3

Executive Order 14110 (Safe, Secure, Trustworthy AI)

Signed October 2023 • Establishes baseline AI safety standards • Requires watermarks for AI-generated content

Directs agencies to develop internal AI governance policies.

Additional Requirements by System Type

- FedRAMP Authorization (cloud-based AI services)
- CUI Protection (if training data includes classified info)
- Privacy Act Section 552a Compliance (for PII handling)
- Section 508 Accessibility (for AI interfaces)

03 | AI SYSTEM PRE-DEPLOYMENT ASSESSMENT CHECKLIST

Use this checklist before beginning any AI procurement or development project. Missing items will cause audit findings later.

DATA GOVERNANCE

- ☐ Training data provenance documented and vetted
- ☐ Data classification verified (CUI, PII, FOUO, Unclassified)
- ☐ Bias assessment completed across protected classes

- ☐ Consent mechanisms in place for personal data usage
- ☐ Data retention and deletion schedules defined

MODEL TRANSPARENCY

- ☐ Model architecture documented for audit review
- ☐ Explainability layer implemented (SHAP, LIME, or equivalent)
- ☐ Decision logic traceable for individual outputs
- ☐ Known limitations documented in SSP
- ☐ Confidence scores displayed for all predictions

SECURITY CONTROLS

- ☐ NIST 800-53 controls mapped to AI-specific risks
- ☐ Encryption at rest and in transit for all model artifacts
- ☐ Access controls defined for model training and inference
- ☐ Vulnerability scanning integrated into CI/CD pipeline
- ☐ Incident response plan includes AI-specific scenarios

OPERATIONAL READINESS

- ☐ Human-in-the-loop process defined for high-risk decisions
- ☐ Monitoring dashboard for model drift and performance degradation
- ☐ Feedback mechanism for users to report errors or concerns
- ☐ Rollback procedures tested and documented
- ☐ Staff trained on AI system operation and ethics

LEGAL & COMPLIANCE

- ☐ Contractual language addresses vendor liability and IP ownership
- ☐ Procurement complies with FAR/DFARS AI guidance
- ☐ FOIA considerations addressed for model disclosures
- ☐ Civil rights impact assessment completed (if applicable)
- ☐ Legal review of automated decision-making processes

Scoring Guide

- ✓ **All boxes checked** → Ready for Development
- ⚠ **Any box unchecked** → Pause and address the gap first

04 | EXPLAINABILITY REQUIREMENTS FOR HIGH-STAKES DECISIONS

Not all AI needs the same level of explainability. Classify your system using this matrix to determine the required depth of documentation.

System Risk Classification Matrix

IMPACT	EXAMPLE SYSTEMS	REQUIRED OUTPUT
HIGH	Benefits denial, parole, hiring decisions, and law enforcement	Full feature-level explanation + human review before action taken
MEDIUM	Resource allocation, fraud detection, and scheduling	Summary explanation + confidence score
LOW	Email routing, document classification, tagging	Category label only

What "Explainable" Means for Federal Use

Local Explainability (Per Decision)

For each output, identify which input features contributed most. Must be understandable by a non-technical stakeholder. Example: "Claim denied because income exceeds \$50,000 AND dependents < 2."

Global Explainability (Model-Wide)

An aggregate view of what factors drive the model overall. Used for bias detection and policy validation. Example: "Income contributes 40% to decisions; age contributes 5%."

Temporal Explainability (Time-Based)

Tracking how explanations change as the model updates. Detecting drift in decision logic over time. Required for continuously learning models.

Documentation Templates (Include in your System Security Plan)

[Model Explainability Statement]

System Name: _____
 Decision Types: _____
 Explanation Method: _____
 Human Review Threshold: _____
 Override Process: _____

[Bias Mitigation Log]

Protected Class Tested: _____
 Disparity Detected: YES / NO
 Corrective Action Taken: _____
 Re-testing Date: _____

05 | CONTINUOUS MONITORING: KEEPING YOUR AI COMPLIANT

Deployment is Not the End — It's the Beginning.

Federal AI systems require ongoing oversight because models drift, new vulnerabilities emerge, regulatory requirements evolve, and user feedback reveals unintended behaviors.

REAL-TIME METRICS	WEEKLY ALERTS	MONTHLY REPORTS
☐ Model accuracy vs. ground truth ☐ Prediction distribution across demographics ☐ Latency and error rates ☐ Human override action count ☐ Failed security scans	☐ Significant drift (>5% baseline) ☐ Bias threshold exceeded ☐ Unusual access patterns or API abuse ☐ POA&M item nearing SLA deadline	☐ Summary of all model changes ☐ Updated risk assessment status ☐ Training data refresh activities ☐ Audit log summary ☐ Complaint resolution status

Automated Triggers

- Accuracy drops below 85% → Flag for human review - Disparity ratio exceeds 1.2 → Block deployment until fixed - Unauthorized access attempt → Lock model + alert ISSO - Configuration drift detected → Roll back to last known good state
--

Recommended Tools

IBM Watson OpenScale	Enterprise ML monitoring
Azure ML Interpretability	Explainability at scale
Amazon SageMaker Monitor	Cloud-native drift detection
Python SHAP/LIME pipelines	Custom open-source monitoring

06 | VENDOR EVALUATION QUESTIONS FOR AI PROCUREMENT

Don't trust vendor claims — verify them with these specific questions.

TECHNICAL CAPABILITIES

1.

What algorithm was used to train the model? Why was this choice made?
2.

Can you demonstrate how your system explains individual decisions?
3.

How does the model handle edge cases or out-of-distribution inputs?
4.

What is your approach to detecting and correcting bias during training?
5.

Can we deploy a copy of the model within our network for validation?

DATA HANDLING

1.

Where was the training data sourced? Do you have proof of consent?
2.

Does the training data contain PII or CUI? How is it protected?
3.

What is your data retention policy? Can we request deletion at the end of the contract?
4.

Have you performed adversarial testing? Share results.
5.

Do you provide full version control and rollback capability for models?

COMPLIANCE SUPPORT

1. Will you help us map your controls to NIST 800-53 and AI RMF?
2. What audit logs do you provide? Are they immutable and tamper-proof?
3. Do you have FedRAMP authorization? Provide the ATO date.
4. How often do you perform third-party security assessments? Share the latest report.
5. What happens if an inspector finds a control violation in your system?

BUSINESS TERMS

1. Who owns the trained model weights after contract completion?
2. What are the costs for scaling beyond the initial license limits?
3. Is there a penalty clause if the system fails to meet performance SLAs?
4. Do you provide staff training on responsible AI use as part of the contract?
5. What exit strategy exists for migrating away from your platform?

⚠ RED FLAGS TO WATCH FOR

- Vague answers about data sourcing ("proprietary methods")
- Refusal to allow independent security audits
- No documentation for how model decisions were reached
- Claims of "bias-free" without empirical testing data
- Pricing structure tied to hours rather than deliverables

07 | 12-MONTH IMPLEMENTATION ROADMAP

Months 1 – 2 Foundation	• Appoint AI Governance Lead (ISSO + Ethics Officer combined role) • Inventory all existing AI/ML systems currently in use • Review current compliance posture against AI RMF • Select monitoring tools and configure dashboards
Months 3 – 4 Policy Dev.	• Draft agency-specific AI governance policy • Define 'High-Stakes' classification criteria • Develop explainability templates for different risk levels • Conduct vendor assessment for procurement projects
Months 5 – 6 Pilot Program	• Select one low-risk AI use case for a controlled pilot • Implement a monitoring dashboard for the pilot system • Train staff on explainability requirements • Gather feedback from end users
Months 7 – 8 Scale Controls	• Apply successful pilot controls to additional use cases • Automate evidence collection for SSP updates • Integrate AI checks into existing DevSecOps pipelines • Begin quarterly executive briefings on AI posture

Months 9 – 10 3rd-Party Val.	- Engage 3PAO for an independent AI system assessment - Address all findings with corrective action plans - Update authorization packages with new AI artifacts - Finalize contracts with clear liability terms
Months 11 – 12 Full Auth.	- Submit complete AI authorization package to AO - Achieve formal ATO with AI-specific conditions noted - Document lessons learned for future deployments - Publish internal metrics to build organizational trust

Success Metrics

✓ 100% of AI systems mapped to NIST AI RMF functions
✓ Zero unexplained high-stakes decisions logged
✓ < 48 hours from anomaly detection to remediation
✓ All vendors pass the evaluation questionnaire
✓ Monthly executive dashboard shows stable compliance posture

NEW SOUTH TECHNOLOGIES

About Us

We specialize in governance-first modernization for federal agencies and state governments in the Washington D.C. metropolitan area. Our team brings over 50 years of combined experience in legacy modernization, governed agility, and responsible AI deployment. We hold active Secret and TS/SCI clearances and are certified in SAE, PMP, and AWS GovCloud.

Contact Us

Email: info@newsouthtechnologies.com
 Website: <https://newsouthtechnologies.com>
 Phone: 703-715-8667
 LinkedIn: www.linkedin.com/company/new-south-technologies

© 2026 New South Technologies. All Rights Reserved.

This Playbook is provided for educational purposes. Consult legal counsel for the interpretation of regulatory requirements specific to your agency.